SECCIÓN 5.8

Priorización, incertidumbre y decisión final

Temas de esta sección:

- Severidad inicial vs severidad real: cómo se construye la prioridad
- Factores que aumentan y reducen prioridad
- La matriz mental de decisión: evidencia × impacto
- Criticidad del activo y del usuario/cuenta
- Cuándo cerrar, monitorear, pedir validación o escalar
- Manejo de incertidumbre: frases útiles y lo que no conviene escribir
- Plantilla simple de decisión · Ocho casos prácticos

La pregunta no es '¿tengo certeza absoluta?' La pregunta es '¿tengo evidencia suficiente para decidir?'

Evidencia	Impacto	Decisión	Ejemplo
FUERTE	ALTO	ESCALAR	*Ejecución maliciosa permitida + persistencia + activo crítico → Escalamiento inmediato.*
FUERTE	BAJO	DOCUMENTAR / MONITOREAR	*Evidencia técnica clara pero impacto limitado → Documentar con precisión.*
DÉBIL	ALTO	VALIDAR RÁPIDO / ESCALAR PREVENTIVO	*Activo crítico + poca evidencia → Validar con prioridad. Si no se puede, escalar.*
DÉBIL	BAJO	MONITOREAR / CERRAR CON JUSTIFICACIÓN	*Poca evidencia + bajo impacto → Mantener en radar o cerrar documentando.*

El mismo evento técnico puede tener urgencia completamente distinta según quién y qué está involucrado:

Criticidad del activo

Alta criticidad (priorizar):
- Controlador de dominio (DC)
- Servidor de archivos financieros
- Sistema de pagos o facturación
- Portal de clientes
- Herramienta de autenticación (AD, IdP)
- Infraestructura de backup

Baja criticidad (analizar pero con menos urgencia):
- Endpoint de usuario sin datos sensibles
- Ambiente de desarrollo aislado
- Sistema de pruebas sin conexión a prod

Criticidad del usuario/cuenta

Alta criticidad:
- Cuentas de administrador de dominio
- Ejecutivos (CEO, CFO, CISO, Director IT)
- Cuentas de servicio con privilegios
- Usuarios con acceso a datos de clientes
- Ingenieros de infraestructura/seguridad

Baja criticidad:
- Usuarios sin acceso a datos sensibles
- Cuentas de demo o temporales sin acceso a prod

⚠ Una cuenta de bajo privilegio comprometida puede convertirse en alta criticidad si sirve para movimiento lateral.

Mismo PowerShell sospechoso: en IT-ADM-02 con ticket → cerrar. En DC-01 sin ticket → escalar inmediatamente.

Después de analizar una alerta, hay cuatro acciones principales:

CERRAR	Evidencia muestra que la actividad es benigna, esperada o bloqueada sin señales adicionales.	*Ej: Despliegue con ticket aprobado, usuario y host en alcance, script corporativo, sin actividad posterior.*
MONITOREAR	Evidencia insuficiente para escalar, pero tampoco suficiente para cerrar sin seguimiento.	*Ej: Dominio raro consultado una vez, sin conexión posterior, sin EDR, sin otros hosts afectados.*
PEDIR VALIDACIÓN	El contexto operativo puede cambiar la interpretación y hay una fuente confiable que puede aclarar.	*Ej: Transferencia de alto volumen, login inusual, uso de herramienta remota, acceso a repositorio sensible.*
ESCALAR	Evidencia indica riesgo relevante, posible compromiso o necesidad de análisis avanzado.	*Ej: Ejecución maliciosa permitida con persistencia. Movimiento lateral. Regla de correo tras login anómalo.*

Cada decisión requiere justificación. Escalar sin contexto y cerrar sin validar son los dos errores más comunes.

5.8 | Manejo de incertidumbre: cómo comunicar sin inventar

Cuando falta evidencia, el analista no debe inventar certeza. Debe documentar la incertidumbre:

✘ Frases que EVITAR (demasiado absolutas sin evidencia):

No pasó nada.	Es seguro.	Es un ataque.	El usuario fue comprometido.
Hubo exfiltración.	Falso positivo.	Es C2.	

✔ Frases CORRECTAS (reflejan el nivel de evidencia):

- No se identificó evidencia de actividad maliciosa en las fuentes revisadas.
- La actividad es compatible con...
- La evidencia disponible sugiere...
- No se pudo validar... debido a falta de visibilidad.
- La actividad fue validada como parte del cambio aprobado.
- La secuencia observada es compatible con posible compromiso de cuenta.
- Se recomienda ampliar revisión o solicitar validación adicional.
- El patrón observado no confirma pero tampoco descarta...

5.8 | Plantilla simple de decisión

Una estructura útil y repetible para documentar cualquier análisis:

QUÉ PASÓ	Se generó alerta por ejecución de PowerShell con parámetros codificados en FIN-LAP-022.
EVIDENCIA OBSERVADA	WINWORD.EXE inició powershell.exe con -nop -w hidden -enc. Luego DNS a billing-check-update.net y creación de update.exe en C:\Users\Public\.
CONTEXTO	Usuario de Finanzas, sin rol técnico. No se encontró ticket o cambio asociado. Horario laboral.
ANÁLISIS	La secuencia es compatible con ejecución inicial mediante documento y posible descarga de payload.
LIMITACIONES	No se revisó correo origen. No se dispone de proxy para validar destino. Hash pendiente.
DECISIÓN	Escalar para análisis avanzado.
PRÓXIMO PASO	Revisar correo origen, hash del archivo, persistencia, conexiones y otros destinatarios del correo.

Esta estructura hace que el análisis sea claro, repetible y útil para quien recibe el caso.

5.8 | Ocho casos prácticos de decisión

Aplicar la matriz de decisión a ocho escenarios reales:

1. Severity:High en IT-ADM-02 con ticket aprobado, usuario IT, host en alcance, sin actividad posterior	**CERRAR**	2. Beaconing cada 60s desde update.exe en C:\Public\, sin firma, padre PowerShell	**ESCALAR**
3. Login exitoso MFA desde IP extranjera en cuenta de RRHH sin actividad posterior	**MONITOREAR**	4. Transfer 6.2GB a Dropbox por usuario que confirma uso para proveedor	**PEDIR VALIDACIÓN**
5. admin.backup conecta por SMB a DC-01 a las 03:14 desde notebook de usuario	**ESCALAR**	6. WAF SQL Injection bloqueado (403) desde IP de scanner automatizado, muchos 404	**CERRAR**
7. WAF Command Injection Alert Only + EDR muestra nginx→bash→curl	**ESCALAR**	8. MFA fatigue: 12 prompts, 11 denied, 1 approved desde IP desconocida a las 01:20	**ESCALAR**

Casos 3 y 4 son los más difíciles: existe actividad real pero la evidencia no justifica escalar todavía. Documentar y mantener en radar es la decisión profesional.